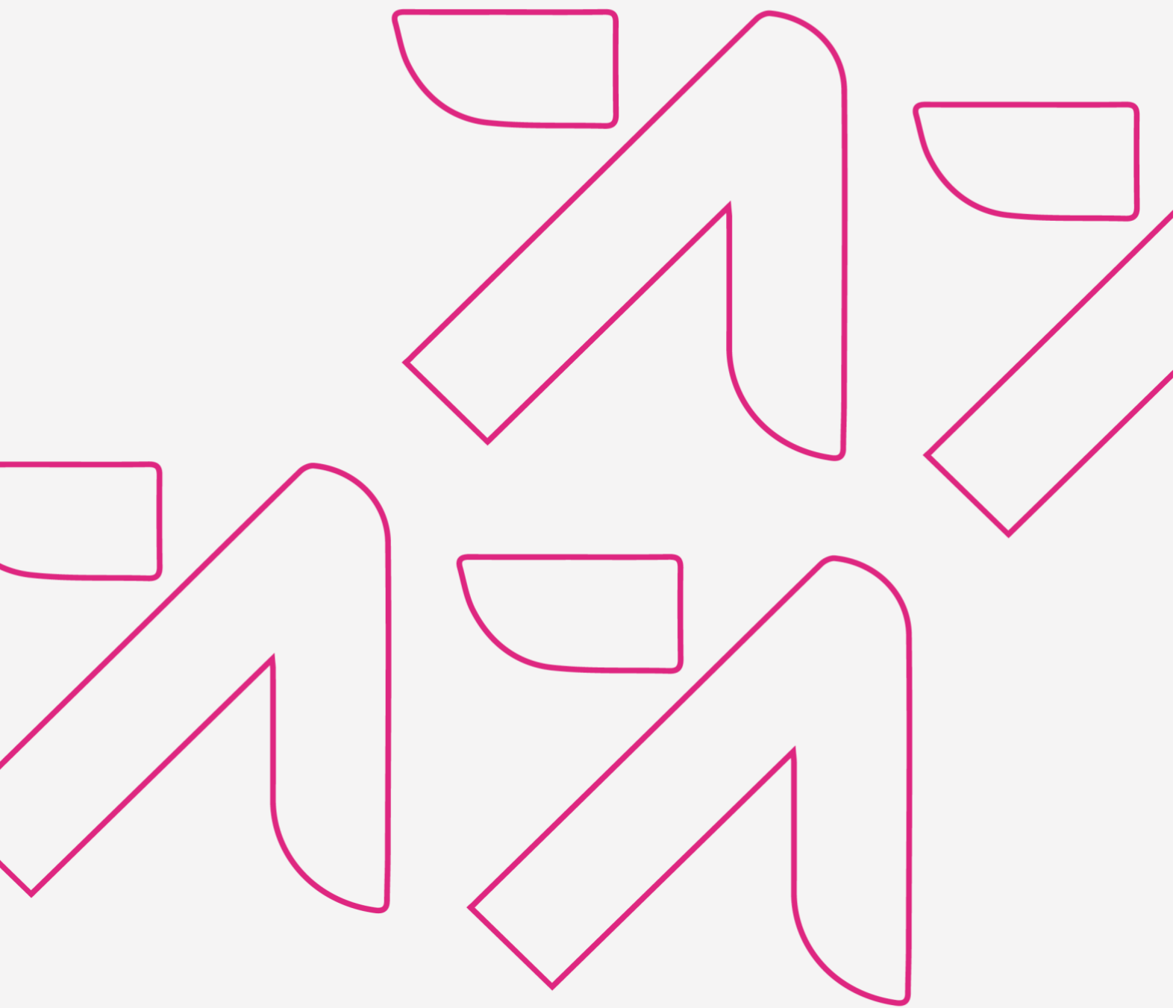




Máster de

Ciberseguridad Hacking Ético

[Módulo Bastionado de Redes y Sistemas]

Curso académico 2026/2027 - Edición Presencial

UT1. Análisis de riesgos y diseño básico de planes de securización

Encaje en el curso 2026/2027: esta unidad desarrolla el RA1 (analizar riesgos y planificar la securización) y corresponde a los temas 1 y 2 del temario oficial.

1. Concepto de riesgo en ciberseguridad

Un riesgo es la posibilidad de que una amenaza aproveche una vulnerabilidad y cause un impacto negativo en la organización. En ciberseguridad no se analiza el riesgo de manera abstracta, sino vinculado a los **activos reales** de la empresa y al impacto directo sobre su operación, reputación o continuidad.

El objetivo de analizar riesgos es priorizar qué debe protegerse primero y decidir qué controles de seguridad tienen sentido para el contexto de la organización.

2. Identificación y clasificación de activos

Un activo es cualquier elemento con valor para la organización y que necesita protección.

Tipos de activos

a) Información

- Bases de datos, registros de clientes, documentación interna, propiedad intelectual.
- Es el activo más crítico en la mayoría de organizaciones.

b) Sistemas y tecnología

- Servidores, aplicaciones, APIs, contenedores, red interna, dispositivos de usuario.
- Mantienen el funcionamiento operativo.

c) Personas

- Empleados, administradores, proveedores, directivos.
- Su conocimiento, accesos y decisiones pueden impactar la seguridad.

d) Infraestructura física

- CPDs, armarios de comunicaciones, switches, routers, cableado.

e) Reputación e imagen de marca

- Confianza del cliente, credibilidad pública.
- Un incidente puede dañarla incluso sin impacto técnico directo.

Clasificación por criticidad

Los **activos** se clasifican según el daño que causaría perderlos, verlos alterados o quedar sin acceso a ellos:

- **Alta criticidad:** Daño grave al negocio.
- **Media:** Afecta procesos importantes pero con alternativas.
- **Baja:** Poca influencia en la continuidad del negocio.

3. Amenazas

Una amenaza es cualquier evento, acción o circunstancia capaz de causar un daño. Pueden ser internas o externas, intencionales o no.

Tipos principales de amenazas

1. Amenazas intencionales

- Malware, ransomware, phishing, APT, atacantes externos, insiders maliciosos.

2. Accidentales

- Errores humanos, configuraciones incorrectas, borrados involuntarios, fallos de proceso.

3. Naturales

- Incendios, inundaciones, seísmos, daños ambientales.

4. Técnicas

- Fallos de hardware, bugs de software, obsolescencia, incompatibilidades.

Cada amenaza debe vincularse a uno o varios **activos** para entender el potencial impacto real.

4. Vulnerabilidades

Una vulnerabilidad es una debilidad que permite que una amenaza tenga éxito.

Tipos habituales

a) Técnicas

- Sistemas sin parches, servicios expuestos, configuraciones por defecto.
- Puertos innecesarios abiertos, TLS obsoleto, contraseñas débiles.

b) De proceso

- Ausencia de procedimientos, políticas inconsistentes, falta de control de cambios.

c) Humanas

- Usuarios sin formación, uso indebido de credenciales, accesos excesivos.

d) De diseño

- Redes planas, falta de segmentación, ausencia de copias de seguridad.

El análisis de vulnerabilidades no se limita a herramientas automáticas: incluye observar cómo funcionan los procesos y cómo se usan los sistemas.

5. Evaluación del riesgo

El riesgo se calcula combinando dos factores:

- **Probabilidad:** Qué tan probable es que una amenaza explote la vulnerabilidad.
- **Impacto:** Consecuencia que tendría para el negocio.

Modelo básico

Riesgo = Probabilidad × Impacto

Ambos valores suelen expresarse en escalas 1–3:

- 1 = Bajo
- 2 = Medio
- 3 = Alto

En metodologías formales se usan escalas más finas (por ejemplo, 1–5). En España la referencia es **MAGERIT v3**, con su herramienta PILAR, que es la que pide el Esquema Nacional de Seguridad; a nivel internacional, **ISO/IEC 27005** y **NIST SP 800-30**. La lógica es siempre la misma que aquí: activos, amenazas, probabilidad e impacto.

6. La matriz de riesgos

La herramienta estándar para visualizar y priorizar riesgos.

Estructura

Una matriz tiene dos ejes:

- **Probabilidad** (baja, media, alta)
- **Impacto** (bajo, medio, alto)

Cada riesgo se ubica según su valoración.

Interpretación

- **Zona roja (críticos):** Riesgos con probabilidad e impacto altos (puntuación 6 o 9).
- **Zona amarilla (moderados):** Puntuación 3 o 4. Requieren seguimiento y medidas parciales.
- **Zona verde (bajos):** Puntuación 1 o 2. Se aceptan y se monitorizan.

La matriz permite ver de un vistazo qué amenazas requieren atención inmediata.

Ejemplo resuelto

Una asesoría de 12 personas con un servidor de ficheros, correo en la nube y una web corporativa:

Riesgo	Probabilidad	Impacto	Valor	Zona
Ransomware en el servidor de ficheros (sin copias fuera de línea)	2	3	6	Roja
Phishing que roba credenciales del correo (sin MFA)	3	3	9	Roja
Caída de la web corporativa (solo informativa)	2	1	2	Verde
Portátil perdido sin cifrar	2	2	4	Amarilla
Incendio en la oficina	1	3	3	Amarilla

Fíjate en que el valor numérico no lo es todo: el incendio puntúa 3, pero su impacto es máximo, así que merece al menos una copia de seguridad fuera de la oficina.

7. Priorización del riesgo

Una vez valorados todos los riesgos, se ordenan según su criticidad.

Criterios habituales

1. **Impacto primero:** Riesgos altos se atienden antes que muchos medios.
2. **Probabilidad realista:** No se sobrevaloran escenarios improbables.
3. **Dependencias:** Un activo crítico multiplica el valor del riesgo.
4. **Coste-beneficio:** Mitigar no siempre es lo mejor (a veces se acepta o se transfiere).

Opciones de tratamiento del riesgo

- **Mitigar:** Reducir probabilidad o impacto mediante controles.
- **Evitar:** Eliminar el proceso o activo que genera el riesgo.
- **Transferir:** Aseguradoras, proveedores o contratos.
- **Aceptar:** Cuando el coste de mitigación es mayor que el impacto.

Riesgo inherente y riesgo residual

- **Riesgo inherente:** el que existe antes de aplicar ningún control.
- **Riesgo residual:** el que queda después de aplicar los controles.

El objetivo no es llegar a cero, sino dejar el riesgo residual por debajo del nivel que la dirección ha decidido aceptar (el apetito de riesgo). Esa aceptación debe quedar por escrito y firmada por quien tiene autoridad para asumirla.

8. Documentación del análisis de riesgos

La documentación debe ser breve, clara y reproducible.

Incluye:

- Alcance del análisis.
- Inventario de **activos**.
- Amenazas y vulnerabilidades identificadas.
- Matriz de riesgos.
- Riesgos críticos con propuesta de tratamiento.
- Riesgo residual y quién lo acepta.
- Fecha de elaboración, responsable y fecha de la próxima revisión.

Una documentación buena evita ambigüedades y es fácil de actualizar en revisiones periódicas.

9. Del análisis al plan de securización

El análisis de riesgos no es el final: es la entrada del plan de bastionado. Cada riesgo que se decide mitigar se convierte en una o varias medidas concretas, con responsable y orden de ejecución.

Riesgo	Medida	Tipo de control	Prioridad
Phishing que roba credenciales	MFA en el correo y formación	Preventivo	1
Ransomware en el servidor	Copias 3-2-1 con una copia inmutable	Correctivo	1
Portátil perdido	Cifrado de disco (BitLocker / LUKS)	Preventivo	2

Para elegir las medidas no hace falta inventar nada: se toman de catálogos de controles ya probados, como el Anexo II del ENS, ISO/IEC 27002, los CIS Controls o las guías CCN-STIC. El resto de unidades del módulo son, en la práctica, el desarrollo de esas medidas.

Para ampliar

- MAGERIT v3 (Portal de Administración Electrónica) y herramienta PILAR (CCN).
- ISO/IEC 27005 y NIST SP 800-30: gestión y evaluación de riesgos.
- Real Decreto 311/2022 (Esquema Nacional de Seguridad), Anexo II: medidas de seguridad.
- CIS Critical Security Controls v8.